

Hasování

Příprava k maturitě - SPŠT IT

Obsah

Úvod do tématu	2
1 Proč se používají hashe?	2
2 LM	3
2.1 Slabiny LM Hashe lze dodnes používat pro útoky:	3
3 NT	3
4 MD5	4
5 SHA	4
6 Bcrypt	4
7 Argon2	5
8 Lámání hesla	5
9 Lámání hesel slovníkovým útokem	5
Další materiály a zdroje	6

Úvod do tématu

Hasování je proces převodu vstupních dat (klíče) na pevně dlouhý řetězec znaků, který slouží jako jedinečný identifikátor pro daná data. Tento proces se provádí pomocí hašovací funkce, která zajišťuje, že i malá změna ve vstupních datech povede k výrazně odlišnému haši. Hašování se široce využívá v oblasti bezpečnosti, například pro ukládání hesel, ověřování integrity dat a digitální podpisy.

1 Proč se používají hashe?

V kryptografických aplikacích je vhodnější pracovat s krátkým reprezentantem zprávy než s celou zprávou, zejména v případě procesu ověřování. Když je hashovací funkce, je nějaká 10 znaků, výstupní má vždy 64 - fixní délka hashe.

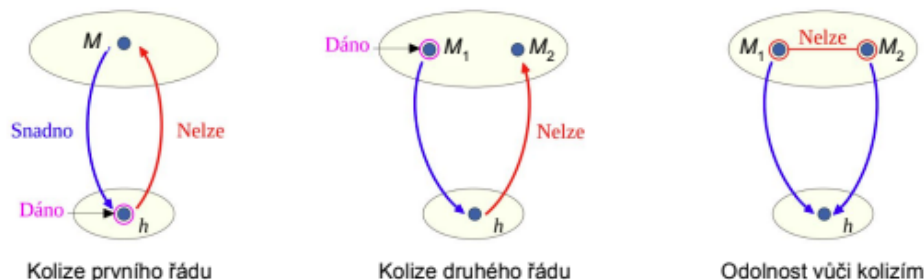
Hlavní důvody, proč se používají hashe

- jednosměrnost – z hashe nelze inverzní operací získat původní data,
- bezkoliznost – vytvořit různé vstupy se stejným otiskem je téměř nemožné,
- rychlost – proces vykonání hashovací funkce je rychlý.

Hash je výsledkem hashovacích algoritmů/funkcí. Je to matematická operace, která „změní“ vložená data na kód tvořený číslicemi a písmeny o určité délce.

V případě kolizí uvažujeme

- **Kolize prvního řádu** – nalezení vzoru **M1** pro výstup **h(M1)**,
- **Kolize druhého řádu** – k dané zprávě **M1** nalezení zprávy **M2** tak, aby platilo $h(M1) = h(M2)$.
- **Odolnost vůči kolizím** – nalezení dvou libovolných zpráv **M** a **M'** pro které platí $h(M) = h(M')$ je velmi obtížné, **ne však zcela nemožné**.



Obrázek 1: „Kolize v hashování - ukázka“

Použití hashovacích funkcí

- otisky zprávy – tvorba digitálních podpisů
- otisk souboru – kontrola integrity, porovnání souborů, schopnost podepsat a prokazovat autorství
- jednoznačná identifikace dat
- otisky hesel – pro uložení hesel
- otisky klíčů – uložení klíčů
- prokazování autorství
- pseudonáhodné generátory

Hashovací funkce

- LM a NT hash - nebezpečne

- RIPEMD
- MD4, MD5, MD6
- CRC-8, CRC-16, CRC-32
- SHA-1, SHA-2, SHA-3
- Whirlpool
- Bcrypt
- Tiger
- Argon2

Nástroje pro lámání hesel

- John the Ripper
- Cain & Abel
- OphCrack
- RainbowCrack
- HashCat

2 LM

NEBEZPEČNÉ.

Funkce založena na šifrování konstanty pomocí DES.

Generuje 128b (16 B) hash.

Zásadní chyby

- rozdělení do 2 bloků
- malé vstupy, velká písmena, 14 znaků

Příklad

- *E473FDFD6A5509C70F94E5CBD9D749E1*

2.1 Slabiny LM Hashe lze dodnes používat pro útoky:

ASCII tabulka umožňuje použít celkem 95 tisknutelných znaků.

Nerozlišuje velká a malá písmena

- velikost písmen omezuje volbu hesla na 69 znaků z ASCII.

Délka hesla je ořezána na 14 znaků

- reálně existuje pouze 69^{14} variant hesel.

Ověřuje se odděleně první a druhá polovina hesla

- útok hrubou silou vyžaduje pouze 2×69^7 pokusů (místo 6914).

Windows XP ukládá LM Hash = NEBEZPEČNÉ.

3 NT

Výstupem funkce je 128 b řetězec (vstup, blok 512b).

NT Hash neobsahuje slabiny z LM Hashe, přesto je považován za prolomenou. V autentizačním NTLMv2 se používá nástupce MD5. Celkem 3 rundy, každá s 16 kroky.

Příklad

- NT: *635AA65C4DEFDC8AB6901B754BDFDF9C*
- MD4: *423af3ab7f943065b99539d264c54657*

4 MD5

Výstupem funkce je 128 b řetězec (vstup, blok 512b).

Celkem 4 rundy, každá s 16 kroky.

Generuje stejný řetězec, jednoduché pro rozpoznání.

Příklad

- *e3dc865c8b8c79dced62b98865d19e7a*

5 SHA

K nejvíce používaným standardům hashovacích funkcí patří SHA, které jsou standardizované americkým úřadem NIST.

K nejznámějším funkcím SHA patří SHA-1, SHA-2 a SHA-3 (preferováno)

- SHA-2: SHA-224, SHA-256, SHA-384, SHA-512, SHA-512/224, SHA-512/256,
- SHA-3: SHA3-224, SHA3-256, SHA3-384, SHA3-512.

Příklady hashů

- SHA-1: *3ae779aa2cbe03e588efedbeb845429b5c714c44*
- SHA-224: *75f5188f309050e1356d5c01cb8880f13a7c7c5504e3b45153ab71ac*
- SHA3-512: *6140f9671c081f2057e30277eb8a963a9a9b14300dea662b5666d7398be8ba6fe92c8*

NSA doporučuje klíče o délce minimálně 128b.

Bezpečné, ale dlouhé a náročné algoritmy.

6 Bcrypt

Hashovací funkce bcrypt byla navržena na základě šifry Blowfish.

Primární účel je hashování hesel a derivace klíčů.

Bcrypt používá původní náhodnou kryptografickou sůl (128b soli).

Výhody hashovací funkce

- heslo je obtížné určit útokem hrubou silou,
- zabraňuje vytváření duhových tabulek.

Vstupem funkce bcrypt je řetězec hesla (až 72 B), číselná cena a 16 B sůl.

Obsahuje více informací, bezpečné.

\$2a\$ 12\$ N5h.Id2S85125bdvTlARi. PzUg.Fg8cJ7udXWVdvbGYSVhXF2jWPG

- Algoritmus
- Cena
- Sůl (pro každou zprávu jiná)
- Hash

Obrázek 2: Struktura bcrypt hashe rozložená na jednotlivé části

7 Argon2

Argon2 je funkce pro hashování hesel, která shrnuje nejnovější poznatky v oblasti návrhu paměťově náročných aplikací nebo odvozování klíčů. Funkce má 3 varianty:

- Argon2i – používá nezávislé výpočty na pozicích v paměti, což zajišťuje odolnost proti útokům postranními kanály.
- Argon2d – používá výpočty, které jsou závislé na pozicích v paměti, vhodný pro úložiště, kde se požadují rychlé výpočty.
- Argon2id – kombinace obou předchozích režimů, všeobecné použití.

`$6$ rounds=5000$ saltsalt$ qFmZHQ.eK0oF.6K/QG.28yvE/I.y.RkQJ.`

• Algoritmus • Parametry • Sůl • Hash

Obrázek 3: Struktura unixového haše (Modular Crypt Format) rozložená na jednotlivé části

8 Lámání hesla

Síla hesel a doba jejich prolomení hrubou silou závisí na počtu znaků, jejich rozsahu a rychlosti udávané jako počet pokusů za 1 sekundu.

Rozsah kombinací určujeme na základě dané množiny znaků

- písmena anglické abecedy (a-Z),
- speciální znaky (@, !, ?, #, ...),
- celá čísla (0-9).

Počet všech možných kombinací vypočteme jako x^y/k , kde x je rozsah kombinací, y je délka hesla a k představuje rychlost lámání hesla [s].

Rychlost závisí na GPU, kde se crackuje, při užití velkých a malých písmen je dokupy 52znaků, takže 52^{na14} .

Příklad

Doba prolomení hesla o délce 6 znaků složené z písmen anglické abecedy a rychlostí lámání $1000000/1s$ se vypočte jako $526/1000000 \approx 19771 s$ (5,49 h).

Maximální rychlost lámání hesel je závislá na výpočetní kapacitě GPU.

9 Lámání hesel slovníkovým útokem

Efektivnějším způsobem lámání hesel je slovníkový útok (dictionary attack).

Útok probíhá tak, že se výrazy ze slovníku postupně nebo paralelně hashují a porovnávají s hashem hesla na vstupu.

Použitím slovníku lze docílit výraznému snížení času potřebného na prolomení hesla, avšak pouze v případě, že se v daném slovníku nachází hledané heslo.

V případě, kdy se heslo v použitém slovníku nenachází, nelze ho prolomit.

Slovníky lze rozlišit na

- nejčastěji používaná hesla,
- (ne)veřejně uniklá hesla,

- vlastní vygenerovaná hesla,
- kombinace různých slovníků.

Jedním z nejpoužívanějších slovníků je rockyou obsahující 14 344 392 hesel.

Duhová tabulka - tabulka hashů, které už existují - slouží k porovnávání hashů

Další materiály a zdroje

- Youtube - Téma
 - Wiki - Téma
-